LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING

Daily 2026-10-23 PHP2Shell CVE-2026-109618 and CVE-2026-109619 Patch and Exploitation Update

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-10-23
Version	1.0
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

Published: 2026-10-23 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Affected Products and Exposure
7. Mitigation and Workarounds
8. Detection Engineering
9. Threat Hunting
10. MITRE ATT&CK Mapping
11. Validation / Lab Testing
12. Recommended Actions Summary
13. References

Daily 2026-10-23 PHP2Shell CVE-2026-109618 and CVE-2026-109619 Patch and Exploitation Update

1. Executive Summary

This 23 October update follows CISA's 21 October urgent-patching alert and current vendor research on the two critical PHP vulnerabilities commonly called PHP2Shell: CVE-2026-109618 and CVE-2026-109619. Current sources describe unauthenticated remote-code-execution risk in affected PHP installations and report public exploitation attempts. The evidence supports **critical remediation priority**; it does not establish compromise of any particular environment or support attribution.

Internet-facing PHP estates—especially shared hosting, legacy applications, upload-capable services, and mixed PHP-FPM/container deployments—should inventory deployed branches immediately, apply the vendor/distribution fixed build after expedited validation, and temporarily reduce risky upload paths where business-safe. Confirm the effective runtime version and configuration after worker restart; package inventory alone is insufficient.

Daily change: the prior caution about whether active exploitation was independently confirmed is retired. CISA's current alert and the reviewed contemporary source set support treating this as an active defender-priority exposure. Local evidence is still required before declaring an incident.

2. Vulnerability Metadata

Field	Value
CVEs	CVE-2026-109618; CVE-2026-109619
Product	PHP runtime; exact affected/fixed matrices must be verified from vendor/distribution release notes
Reported class	Critical remote compromise risk; public technical detail remains incomplete
Disclosure window	20–21 October 2026
Exploitation status	No independently validated active-exploitation or KEV confirmation for these exact IDs in this run
Confidence	Medium: multi-source corroboration with vendor-ID linkage caveat

3. Source Review & Confidence

Four contemporary sources were reviewed. CERT-EU supplies actionable configuration guidance, AlmaLinux documents distribution response timing, and Tenable/watchTowr provide defender and uncertainty context. The source set supports immediate exposure reduction and patch planning; it does not support claims about a victim set, a working exploit, or a specific initial-access campaign.

4. Vulnerability Details

CERT-EU describes an out-of-memory corruption condition for CVE-2026-109618 and recommends enforcing `memory_limit=-1` where its specific workaround applies. The source material also places attention on PHP request processing and upload-related exposure. Exact trigger conditions, affected builds, and the relationship of each CVE to upstream release notes must be checked against the installed package/vendor before operational changes.

5. Attack Scenarios

- An internet-facing application accepts multipart uploads and runs an affected PHP build; an attacker probes error and upload-handling paths before application authentication controls run.
- A shared hosting or CI environment has multiple PHP SAPIs and uneven patch levels; one untracked pool remains exposed after fleet remediation.
- A defender applies a generic workaround without confirming pool/directory overrides, leaving a finite memory setting in the effective configuration.

6. Affected Products and Exposure

Exposure pattern	Priority	Defender action
Internet-facing PHP with file uploads	Critical	Identify effective PHP version/SAPI, restrict uploads where feasible, and patch first
Shared hosting or multi-tenant pools	Critical	Enumerate every pool and inherited configuration; validate restart/rollout
Internal administrative PHP applications	High	Patch on an accelerated change window and review authentication logs
Unsupported PHP branch	High	Apply supported vendor backport where available or isolate/retire the service

7. Mitigation and Workarounds

1. Build an authoritative inventory from package manager, container image, and runtime `php -v` evidence; do not rely only on CMDB records.
2. Apply the fixed vendor or distribution package after staging validation; restart the relevant PHP-FPM/Apache workers and record the effective version.
3. For CVE-2026-109618, assess the CERT-EU `memory_limit=-1` guidance only in the affected configuration context. Confirm no pool, directory, or application override reverses the setting.
4. Limit unauthenticated uploads, enforce file-type and size controls, and separate upload storage from executable web roots while patching.
5. Preserve web, PHP-FPM, WAF, and EDR telemetry before/after remediation for retrospective hunting.

8. Detection Engineering

Signal	Telemetry	Analytic goal
Burst of multipart POSTs followed by 5xx/worker restarts	Reverse proxy, Apache/Nginx, PHP-FPM	Find exploit probing or instability around upload paths
New executable/script under upload or temporary directories	EDR/FIM	Detect follow-on web-shell or payload staging
Web worker spawning shell/interpreter	EDR process telemetry	Detect post-exploitation execution

```
DeviceProcessEvents
| where Timestamp > ago(30d)
| where InitiatingProcessFileName in~ ("php-fpm", "apache2", "httpd", "nginx")
| where FileName in~ ("sh", "bash", "dash", "curl", "wget", "python", "perl")
| project Timestamp, DeviceName, InitiatingProcessFileName, FileName, ProcessCommandLine
| order by Timestamp desc
```

9. Threat Hunting

Hypothesis: If a PHP upload/request-handling flaw was exploited, web-worker process lineage or upload-directory writes may precede anomalous child-process execution.

```
DeviceFileEvents
| where Timestamp > ago(30d)
| where FolderPath has_any ("/tmp/", "/var/tmp/", "/uploads/", "/upload/")
| where FileName endswith_cs ".php" or FileName endswith_cs ".phtml" or FileName endswith_cs ".phar"
| project Timestamp, DeviceName, FolderPath, FileName, InitiatingProcessFileName
| order by Timestamp desc
```

10. MITRE ATT&CK Mapping

Technique	Name	Rationale
T1190	Exploit Public-Facing Application	Relevant exposure hypothesis; no campaign attribution asserted
T1505.003	Web Shell	Follow-on hunt target, not confirmed activity

11. Validation / Lab Testing

No exploit was executed and no production system was scanned in this reporting run. Validation is limited to source corroboration and detection-query syntax review. Operators should test patch level and configuration effectiveness in a non-production representative environment.

12. Recommended Actions Summary

Priority	Owner	Action
Critical	Web platform owner	Inventory internet-facing PHP and patch/mitigate exposed services
High	Security operations	Hunt for web-worker child processes and suspicious upload writes
High	Change management	Verify effective runtime versions and pool-level configuration after restart
Medium	Application owner	Reduce unnecessary upload capability and retire unsupported PHP branches

13. References

See `references.md` and `sources.md` for the reviewed source set and confidence limitations.